

Project 4: Windows Server

Robert Simpson

University of Maryland Global Campus

DFCS 625: Windows Forensics

Randy Grizzelli

July 7th, 2026

Overview

Project 4 includes your answers to essay questions and collections from your lab activities. This project focuses on DFIR Windows Server analysis of an Active Directory environment.

Report

1. What is an Active Directory (AD) domain? What is an AD Tree domain? What is an AD forest? What is a child domain? How are they incorporated into an AD environment? (Unit 7)

Active Directory is a Microsoft management solution. It allows an organization to manage people, groups, and devices through one centralized system called the domain controller. To further explain, an example will be provided. Company XYZ has an IT department, HR department, and accounting department. In the XYZ Active Directory, user accounts, security groups, computers, printers, and other systems that need to be joined to the domain. If company XYZ had another branch located in another state, that branch may have its own domain. However, since they are part of the same company and likely have the same policies, they could be joined together in what is called an Active Directory Tree (Dauti, 2019). These two domains would then trust each other (Dauti, 2019). Or these domains to trust each other, Active Directory utilizes the Net Logon service along with remote procedure call to build a trust path between the two domain controllers (Justinha, 2023). If these two companies were owned by either a central company headquarters or a parent company that had its own tree domain, they may all be joined together in an Active Directory Forest. This exists when multiple domains join together to create a Tree, and then multiple Trees join to create a Forest (Dauti, 2019). It is a hierarchical structure that allows for trust to be established across domains and make it easier for system administrators to manage users, groups, and computers. Two forests can trust each other by first ensuring their DNS is configured properly by either having a shared root DNS or conditional forwarders (Justinha, 2023). Then administrators in both forests can utilize a shared, known password to establish trust (Justinha, 2023). Company XYZ with an office in New York City is

the root domain. The company expanded and now has branches in Trenton, NJ and Philadelphia, PA. In the companies Active Directory, these two branches became children domains of the parent domain in NY. This made it easier for the system administrators to assign policies and manage the branches (Dauti, 2019).

The system administrator could create security groups for these departments. The IT department has 3 people, one of which is the system administrator. Applying the principles of least privilege, the administrator may have access to an administrator account as well as a less privileged account to do the majority of work on. The other two members of the IT team may have slightly elevated privileges that allow them to perform password resets. The members of the HR and accounting departments would most likely have basic accounts. The system administrator would utilize the administrator account on the domain controller to manage the organization's Active Directory. This could entail creating accounts, deleting old accounts from past employees, as well as other services like managing group policy.

2. What is a domain controller in an AD environment? What are organizational units (OUs)? What OUs can a DFIR analyze to identify a threat actor's persistent foothold? (Unit 7)

Continuing the example of company XYZ, it has been established what the Forest, Tree, Root Domain, and Child Domain are. The system administrator needs a system to manage all users, groups, and systems in a centralized location. The domain controller provides this function (Dauti, 2019). In many cases, this will be a Windows Server virtual machine that has been set up to be the domain controller through the Windows Server Manager configurations. This single system manages the entire Active Directory for the organization and has root level permissions, meaning it is both in need of redundancy and security. In most organizations, there will be a primary domain controller and a backup domain controller (Dauti, 2019). This redundancy

ensures that if anything happens to the primary domain controller, the backup, which has the same configurations, can step up to be the primary until services are restored.

As mentioned, many times above, the system administrator manages users, groups, and systems in Active Directory. How this is organized is through organizational units or OUs. These are a series of folders that follow a hierarchical structure (Dauti, 2019). The user, Sam, is a OU. Sam is in the Users OU. The Users OU may be in a higher OU like Accounting depending on the organization. Sam now has the privileges and policies that apply to the Users and Accounting OUs. This is a parent and child relationship (Dait, 2019).

If a threat actor would want to establish persistence and have elevated privileges, OUs with administrator privileges would be a perfect place. In large organizations, the Active Directory can become a mess overtime if previous system administrators did not properly manage it. Accounts get created as new employees join, but they do not always get deleted when they leave. Common high value OUs, as seen in the unit 7 lab, are Domain Controllers, Domain Admins, Administrators, and Enterprise Admins. This creates a perfect spot for a threat actor to hide as the system administrator may not notice one extra account. If old system administrator accounts are not deleted, the threat actor could disguise there as well. The DFIR analyst could analyze administrator OUs as well as any OUs that have some form of elevated privileges.

3. What advantages does a Windows 365 environment have over an Azure Virtual Desktop for DFIR analysis? What disadvantages does a Windows 365 environment have? (Unit 7)

One of the primary advantages of Windows 365 is its simplicity (Brinkhoff et al., 2023). This simplicity extends to both the user, the business owner paying for it, and the system administrator managing it. It builds on what many users who have used Windows computers

before are familiar with instead of introducing a new concept to them such as a virtual desktop interface. One big advantage for the business owner is the pricing as it is just per user per month (Brinkhoff et al., 2023). This makes managing accounts and billing for the business owner a lot easier. This is a small but important part for small business owners in choosing Windows 365 over AVD. Additionally, Windows 365 has many preset models that fit a variety of business needs. One of the most unique ones is Windows 365 Frontline. This model is designed for businesses that have shift workers (Brinkhoff, 2023). A guitar manufacturer may have only a few computers but they get used by a different person each shift. The business owner is only paying for a few licenses so long as only one user is logged in at a time for that system (Brinkhoff, 2023). This again goes back to what is easiest for the business owner in terms of payment and application. For the DFIR analyst, Windows 365 environments can be easier. The key to Windows 365 environment is that it is a dedicated cloud PC for that user (Brinkhoff et al., 2023). This dedicates resources whereas AVD shares resources between multiple users, running them on virtual machines, which can make it more difficult for the analyst to track what user did what on the machine.

Windows 365 is not perfect and does come with disadvantages. Regardless of how much a user uses the system, with Windows 365 the payment is fixed (Brinkhoff et al., 2023). This can be advantageous if a lot of compute is being used. However, if it is only a system that gets used occasionally, the owner ends up paying for more than they need. With Azure Virtual Desktop, it is a pay as you use model. This benefits businesses with unpredictable user engagement. For the analyst, it could also be an issue since Microsoft handles the back end of the system (Apporto,

2026). In a criminal investigation, separate warrants may be required to get further evidence from the machine.

4. As a DFIR investigator, you identify that the compromised system you are analyzing is the only system running a vulnerable version of Windows. What indicators can you use to verify that the system was intentionally unpatched? Why is vulnerability management important to maintain a Windows environment's security posture? (Unit 8)

There are a few ways to detect if a system was intentionally unpatched. First, many organizations have security policies and standard operating procedures. These lay out in clear terms what the organizations rules are for security implementation such as how often to check for software updates, when to apply updates, password policies and when to scan for vulnerabilities. In many cases, scanning is automated. The policy may state that all systems get scanned after business hours once a week. If one system suddenly misses getting scanned either one or more times this is a possible indicator. However, as author Magnusson mentions, external data such as current CVEs as well as exploratory scans using Nmap, add additional needed information (2020). Looking at event logs may show that a system had their automatic updates turned off. This is another indicator. Nmap scans may show a suspicious device on the network which is another indicator. Recent CVEs may point to a new vulnerability that a recent patch fixed. All of these indicators combine to tell a story that a system was intentionally unpatched.

All of these point to what is known as vulnerability management. It is knowing both what is going on in your environment as well as staying informed on what threat actors are doing and what software vulnerabilities exist (Magnusson, 2020). For a Windows environment this can mean keeping automatic updates on and following Patch Tuesdays.

5. What are Department of Defense (DoD) Security Technical Implementation Guides (STIGs)? What are DoD Security Requirements Guides (SRGs)? (Unit 8)

Security Technical Implementation Guides, or STIGs, are checklists of configuration requirements depending on the system and/or operating system (Warfighting Acquisition University, 2026). DISA is the government agency that develops the STIGs and maintains them. They are a requirement of federal systems that access DoD networks (Warfighting Acquisition University, 2026). A simple example may be that on Windows 11 systems, checking for automatic updates must be enabled. As can be viewed in Figures 13, 14, and 15, there are 3 categories of severity for STIG compliance. CAT I is the most severe and in order for an Authority to Operate (ATO) to be granted they must be fixed (Tenable, 2014). The reason for this is that CAT I findings mean the vulnerability allows for direct privilege escalation (Tenable, 2014). CAT II findings are slightly less severe and will not directly prevent an ATO from being granted. These findings mean that privilege escalation is possible (Tenable, 2014). CAT III, the least severe, are recommendations to improve overall security posture, but are not required (Tenable, 2014).

DoD Security Requirements Guides tell an organization what the baseline security posture for a system and/or operating system must be (stevevi, 2023). This security posture is determined by NIST SP 800-171, Risk Management Framework, and other policies depending on if it is for cloud services or not.

Unit 7 Lab

1. What is the Administrator Account's SID? What is the SID of the threat actor account you created? Include a screenshot of your findings.

The Administrator Account's SID, as seen in Figure 1, is 5-1-5-21-1706419833-1422595341-2278560970-1000.

The Threat Actor account's SID, as seen in Figure 2, is 5-1-5-21-1706419833-1422595341-2278560970-1104.

Figure 1: Administrator SID

```
distinguishedName : CN=Administrator,CN=Users,DC=DFCS625,DC=local
name              : Administrator
objectClass       : user
objectGUID        : bf9ac099-3d88-408a-8e57-7c9dfb1377d5
SamAccountName    : Administrator
SID               : S-1-5-21-1706419833-1422595341-2278560970-1000
```

Figure 2: Threat Actor SID

```
distinguishedName : CN=Threat Actor,CN=Users,DC=DFCS625,DC=local
name              : Threat Actor
objectClass       : user
objectGUID        : cd2f1d97-8ed5-44be-8657-4ca84c683de5
SamAccountName    : threatactor
SID               : S-1-5-21-1706419833-1422595341-2278560970-1104
```

2. Review your ADGroups.csv saved file. What is the SID of the Administrator account? Why are there multiple Admin accounts? Include a screenshot of your findings.

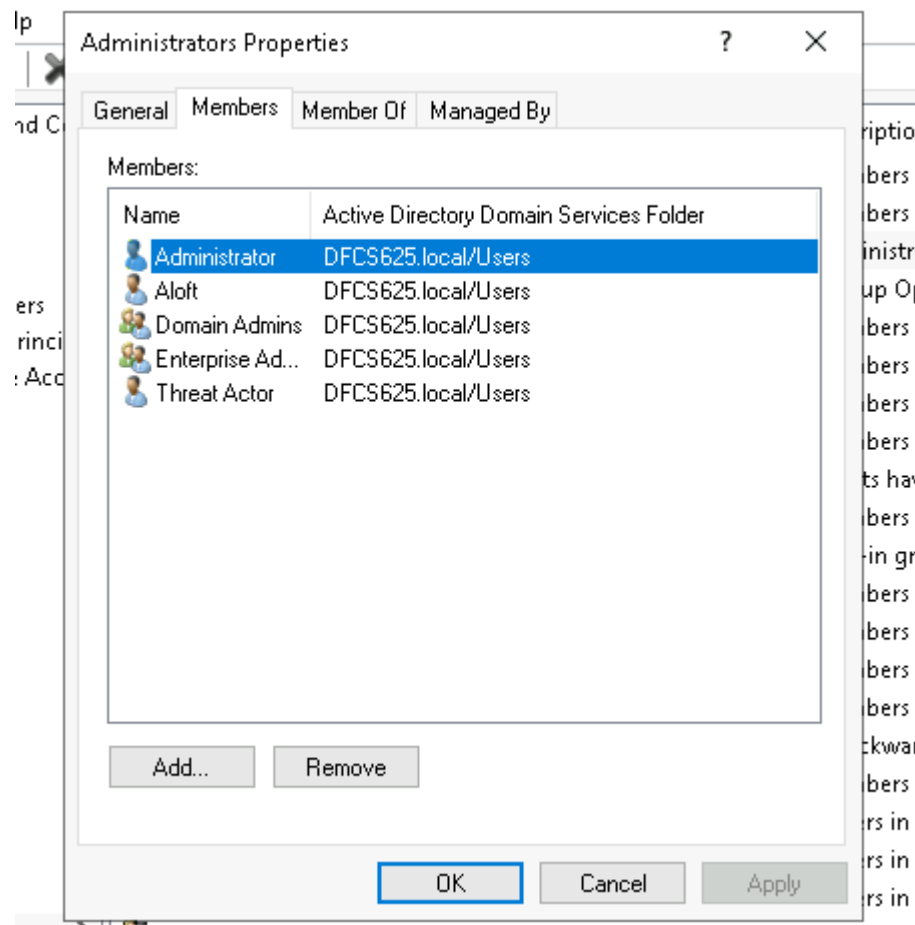
The Administrator Account's SID, as seen in Figure 1, is 5-1-5-21-1706419833-1422595341-2278560970-1000.

3. What Active Directory group members are in the Administrators Group? Are all the members users? Include a screenshot of your findings.

The Active Directory group members in the Administrators Group, as seen in Figure 3, are: Administrator, Aloft, Domain Admins, Enterprise Admins, and Threat Actor. No, not all members are users. The users are Administrator, Aloft, and Threat Actor as denoted by their

graphical image. Domain Admins and Enterprise Admins are groups as denoted by their graphical image.

Figure 3: Members of the Administrators group



4. Your organization sustained a network intrusion, and the threat actor is believed to have gained administrator privileges on the AD server. Would your investigation of persistence include only reviewing the Administrator Group members? Would you review all the group members? Why or why not?

Reviewing all group members would be the wiser choice. The reason for this is that, as seen in Figure 3, there are also Domain Admins and Enterprise Admins groups. The threat actor could have persistence in other groups with administrative privileges than just Administrators group.

Unit 8 Lab: Part 1

1. What Windows version is the WINSERVERTGT running? Include a screenshot of your findings.

The Windows version is Windows Server 2019 Version 1809 OS Build 17763.5329 as seen in Figure 4.

Figure 4: Windows Version of the WINSERVERTGT system



2. What is the most recent update in the Windows update history? What does this finding tell you about the system? Would an effective vulnerability management program have resulted in different findings? Hint: The version and build can help to identify when the system was last updated.

The system has not been checked since 2/5/2024 at 6:40PM as seen in Figure 5. Figure 6 shows that the last installed updates were on 12/30/2023 and 12/31/2023. These findings show that the system does not have automatic updates schedule nor has it been manually updated or checked since the dates mentioned above. According to Microsoft's website, an update for Windows Server 2019 was released on June 9, 2026 (2026). This shows that the server is severely out of date. An effective vulnerability management program would have resulted in different findings by having automatic updates at least checked, though not necessarily deployed, as well as manually verified. Figure 7 also shows all the missing updates.

Figure 5: Status of WINSERVERTGT updates

Windows Update

***Some settings are managed by your organization**
[View configured update policies](#)



You're not up to date

Last checked: 2/5/2024, 6:40 PM

Your device is missing important security and quality fixes.

Check for updates

***Your organization has turned off automatic updates**

[Change active hours](#)

[View update history](#)

[Advanced options](#)

Figure 6: Last updates to be installed on WINSERVERTGT

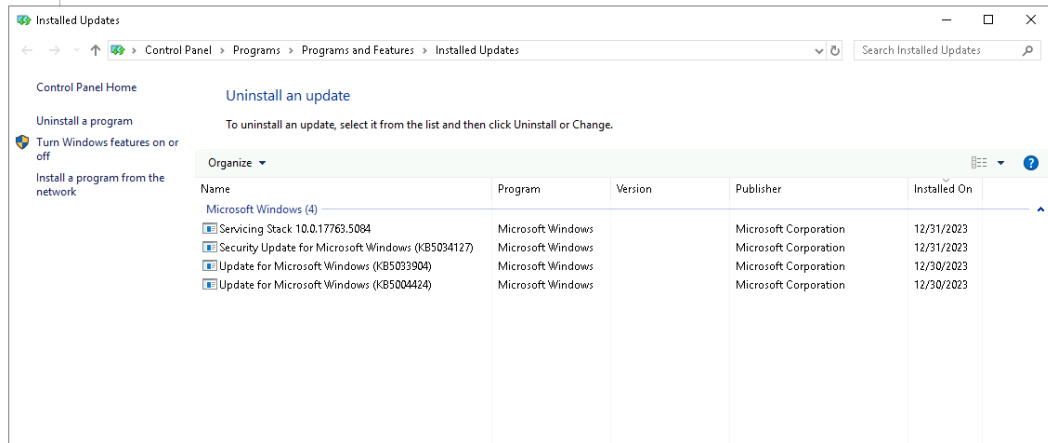


Figure 7: Missing updates on WINSERVERTGT



Updates available

Last checked: Today, 4:57 PM

Your device is missing important security and quality fixes.

Security Intelligence Update for Microsoft Defender Antivirus - KB2267602 (Version 1.453.310.0) - Current Channel (Broad)

Status: Installing - 0%

Windows Malicious Software Removal Tool x64 - v5.142 (KB890830)

Status: Pending download

2026-06 Cumulative Update for Windows Server 2019 (1809) for x64-based Systems (KB5094123)

Status: Pending download

2026-05 Cumulative Update for .NET Framework 3.5, 4.7.2 and 4.8 for Windows Server 2019 for x64 (KB5088864)

Status: Pending download

2021-01 Update for Windows Server 2019 for x64-based Systems (KB4589208)

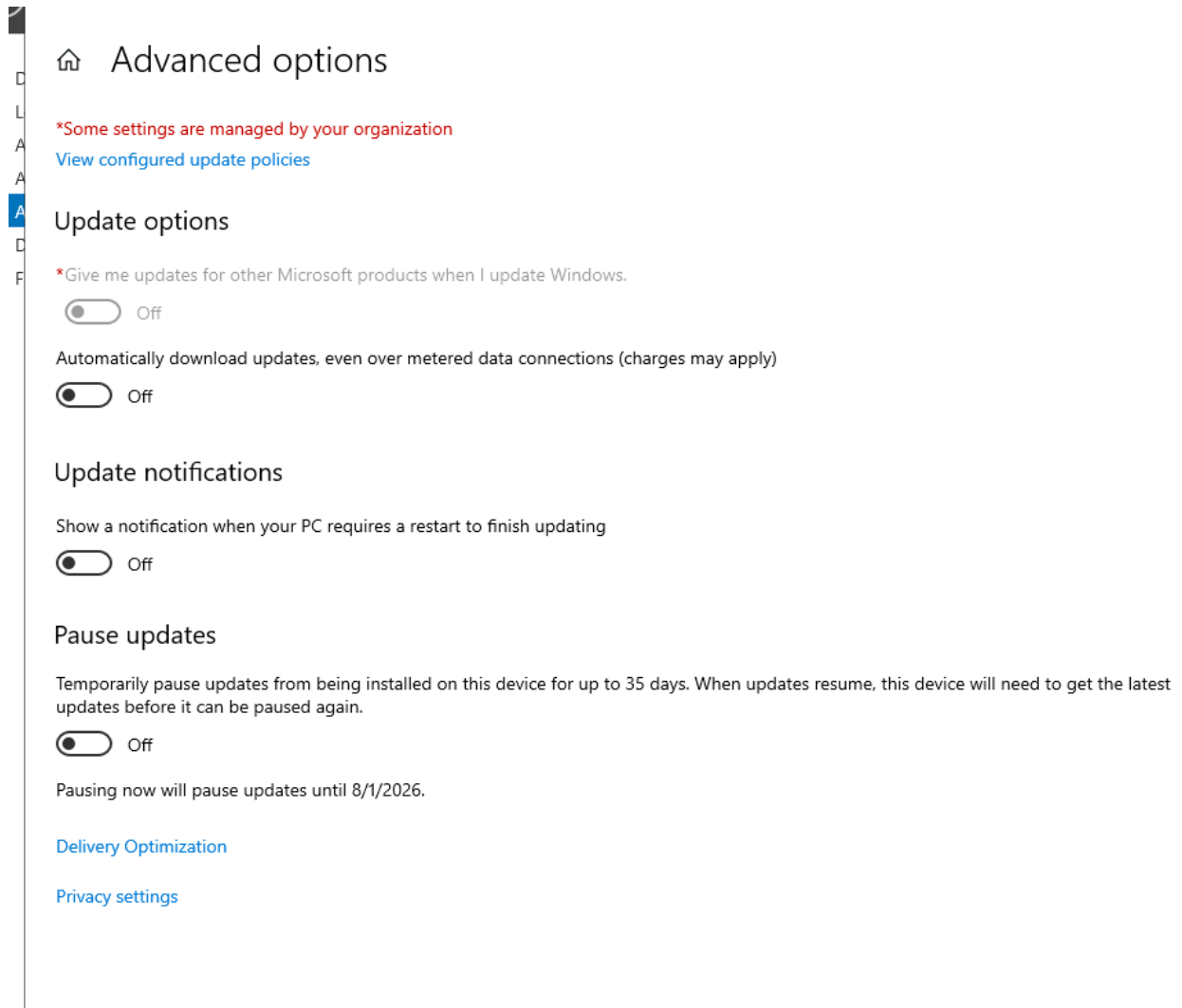
Status: Pending download

*Your organization has turned off automatic updates

3. What “important security and quality fixes” is the server missing? Why are they missing, and what organizational setting can be attributed? Screenshot your findings.

The server is missing having advanced options “Update Notifications” on which would let the user know the system needs to be updated as seen in Figure 8. Additionally, though not all organizations would want this, automatic updates are turned off. Some organizations may not want Windows to update during working hours and instead update over night. Applications like Software Center can be configured to do this from experience. These could be missing intentionally due to a bad actor adjusting settings.

Figure 8: Updates options as configured on WINSEVERTGT



Unit 8 Lab: Part 2

1. What are the Original and Adjusted Scores of your SCAP Compliance Checker results? What does this score represent? Include a screenshot of your findings.

The original Score for the SCAP Compliance Checker results was 46.49%.

The adjusted score for the SCAP Compliance Checker results was 46.49%
The score represents what percentage of rules passed compared to the total findings.

Figure 9: Original Score Results Tab

Results				
Host Name	Content	Score	Errors	Warnings
WINSERVERTGT	Windows_Server_2019_STIG	46.49	0	1

Figure 10: Original Score All Settings Report

All Settings Report - Microsoft Windows Server 2019 STIG SCAP Benchmark

SCAP Compliance Checker - 5.14.1

Score | System Information | Content Information | Results | Detailed Results

Score

46.49% *

Adjusted Score: 46.49% *

Original Score: 46.49% *

Compliance Status: RED

* Actual compliance unknown due to: unanswered manual questions: 36

Pass: 106	Not Applicable: 18	BLUE: Score equals 100
Fail: 122	Not Checked: 36	GREEN: Score is greater than or equal to 90
Error: 0	Not Selected: 0	YELLOW: Score is greater than or equal to 80
Unknown: 0	Informational: 0	RED: Score is greater than or equal to 0
Fixed: 0	Total: 282	

Figure 11: System information for the system

System Information

Target Hostname:	WINSERVERTGT
Operating System:	Microsoft Windows Server 2019 Datacenter
OS Version:	1809
Domain:	DFCS625.local
FQDN:	WINSERVERTGT.DFCS625.local
Processor:	Intel(R) Xeon(R) Platinum 8272CL CPU @ 2.60GHz
Processor Architecture:	Intel64 Family 6 Model 85 Stepping 7
Processor Speed:	2594 mhz
Physical Memory:	8192 mb
Manufacturer:	Microsoft Corporation
Model:	Virtual Machine
Serial Number:	0000-0002-1109-8479-7487-9733-04
BIOS Version:	Hyper-V UEFI Release v4.1
Interfaces:	• [00000002] Microsoft Hyper-V Network Adapter ○ IP Addresses ■ 10.11.153.119 ○ MAC Address: 00:0D:3A:19:4C:19

2. How many Category I, Category II, and Category III findings are open? What is the difference between Open, Not Reviewed, and Not a Finding? Take screenshots of your findings.

The system had 13 CAT I, 90 CAT II, and 3 CAT III findings open. When comparing the numbers between figures 10 and 12, it can be derived that Open findings are findings that failed the check and have not been resolved. Not reviewed findings require a manual check which can therefore affect the adjusted score of the report. Not a finding denotes a check that passed and requires no alteration.

Figure 12: Original Findings in STIG Viewer

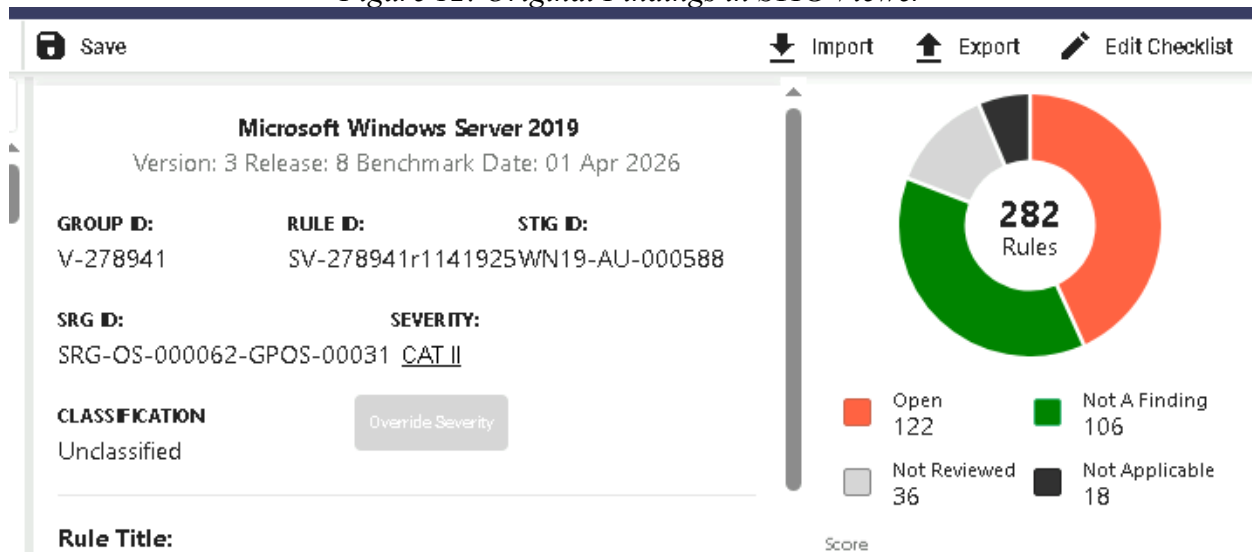


Figure 13: 34 CAT I vulnerabilities

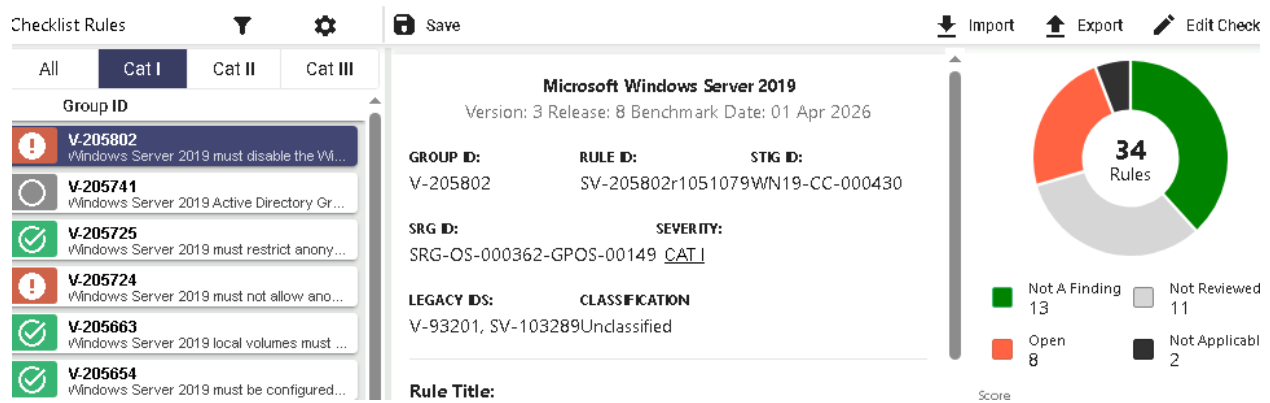


Figure 14: 234 CAT II vulnerabilities

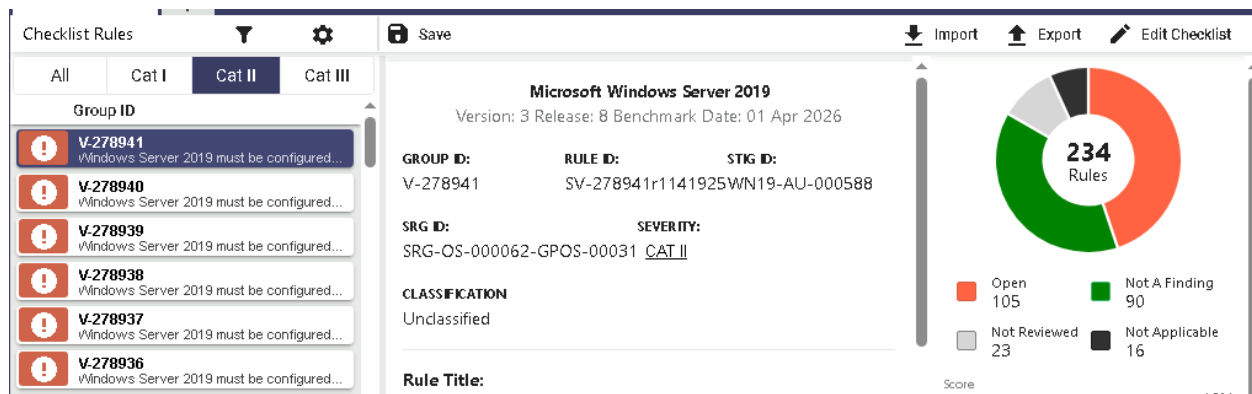
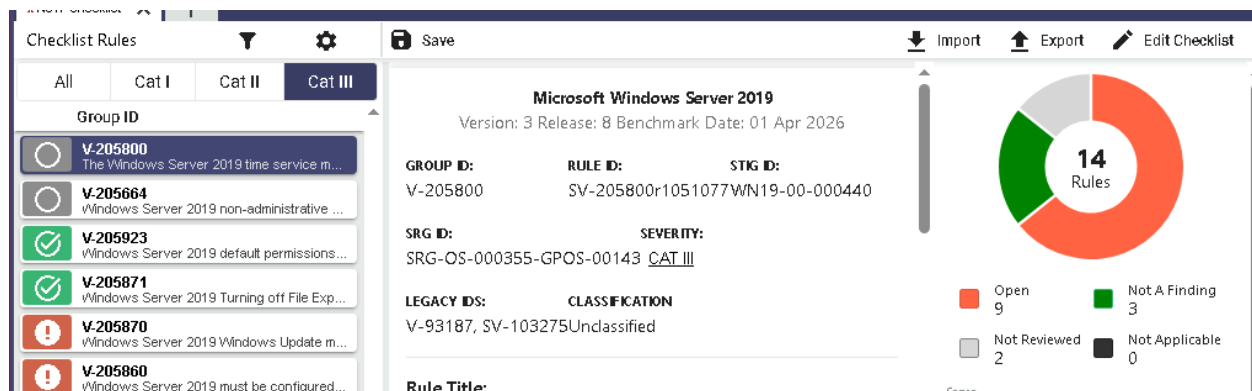


Figure 15: 14 CAT III vulnerabilities



- Inspect a Not Reviewed rule. Review the Check Text in each of the rules. How is the Not Reviewed Rule check completed? What is a manual check?

As discussed earlier, a manual check requires the user to follow the check text and manually see if the security recommendations are in place. This is how Not Reviewed rules are checked.

Figure 16: Check Text of Not reviewed rule

	V-278941 Windows Server 2019 must be configured...
	V-278940 Windows Server 2019 must be configured...
	V-278939 Windows Server 2019 must be configured...
	V-278938 Windows Server 2019 must be configured...
	V-278937 Windows Server 2019 must be configured...
	V-278936 Windows Server 2019 must be configured...
	V-278935 Windows Server 2019 must be configured...
	V-278934 Windows Server 2019 must be configured...
	V-271429 Windows Server 2019 must be configured...
	V-271428 Windows Server 2019 must be configured...
	V-205866 Windows Server 2019 group policy object...
	V-205851 Windows Server 2019 must have a host-b...
	V-205842

enabled, such a system can stop and/or alert for many attempts to gain unauthorized access to resources.

Check Text:

Determine if there is a HIDS and HIPS on each server.

A HIDS device is not required on a system that has the role as the Network Intrusion Device (NID). However, this exception needs to be documented with the information system security officer (ISSO).

If a HIDS and HIPS are not installed on the system, this is a finding.

Fix Text:

Install a HIDS and HIPS on each server.

- Inspect a Not a Finding rule. How does the SCAP Compliance Checker validate rule compliance? What artifacts is the SCAP Compliance Checker using to locate specific settings and configurations?

As done in the lab, it started with downloading the correct SCC version for Windows. The program was ran on the Windows Server 2019 and only scanned against Windows Server 2019 STIG. The program then proceeded to scan the system. It produced a report which was saved as an XCCDF file. In STIG Viewer this is then compared against the set of STIGs which results in the score being given. Looking through the results shows that SCC looks through system settings, group policy settings, and registry settings.

Figure 17: Screenshot of Not a Finding rule

The screenshot displays the STIG Viewer 3.7: STIG Checklists application. The interface is divided into several sections:

- Left Panel:** A list of checklist rules. Rule V-205813, "Windows Server 2019 User Account Control...", is highlighted with a green checkmark icon, indicating it is a "Not a Finding".
- Center Panel:** Details for the selected rule V-205813.
 - Value Name:** EnableLUA
 - Value Type:** REG_DWORD
 - Value:** 0x00000001 (1)
 - Fix Text:** Configure the policy value for Computer Configuration >> Windows Settings >> Security Settings >> Local Policies >> Security Options >> "User Account Control: Run all administrators in Admin Approval Mode" to "Enabled".
 - References:** CCI-002038. The organization requires users to reauthenticate upon organization-defined circumstances or situations requiring reauthentication. - NIST SP 800-53 Revision 4 :: IA-11, - NIST SP 800-53 Revision 5 :: IA-11.
 - Comments:** Rule Result: Pass, Criteria: true (All child).
 - Finding Details:** Tool: cpe:/a:niwc:scc:5.14.1, Time: 2026-06-28T14:18:04.
- Right Panel:** A summary section including a donut chart showing 282 total rules, with a breakdown: Open (122), Not A Finding (106), Not Reviewed (36), and Not Applicable (18). Below the chart is a score of 46% and a checklist type of "Computing".

References

Apporto. (2026, June 18). *Windows 365 vs Azure Virtual Desktop: A Detailed Comparison*

Apporto. Apporto. <https://www.apporto.com/windows-365-vs-azure-virtual-desktop>

Brinkhoff, C., Patnaik, S., & Pedholt, M. (2023). *Mastering Windows 365: The ultimate guide to designing, delivering, and managing architectures for Windows 365 cloud PCs*. Packt Publishing

Dauti, B. (2019). *Windows Server 2019 administration fundamentals - Second edition*. Packt Publishing.

Justinha. (2023, October 6). *How trusts work for Microsoft Entra Domain Services*.

Learn.microsoft.com. <https://learn.microsoft.com/en-us/entra/identity/domain-services/concepts-forest-trust>

Magnusson, A. (2020). *Practical vulnerability management: A strategic approach to managing cyber risk*. No Starch Press.

Microsoft. (2026). *June 9, 2026—KB5094123 (OS Build 17763.8880) - Microsoft Support*.

Microsoft.com. <https://support.microsoft.com/en-us/topic/june-9-2026-kb5094123-os-build-17763-8880-19adceff-e266-40ec-8a10-df4bb0e320ea>

Stevevi. (2023, April 5). *Department of Defense Impact Level 4 - Azure Compliance*.

Microsoft.com. <https://learn.microsoft.com/en-us/azure/compliance/offerings/offering-dod-il4>

Tenable. (2014, December 18). *STIG Alerts (by CAT)*. Tenable®. <https://www.tenable.com/sc-dashboards/stig-alerts-by-cat>

Warfighting Aquisition University. (2026). *Security Technical Implementation Guide*. Waru.edu. <https://www.waru.edu/acquipedia-article/security-technical-implementation-guide-stig>

